

CONTENTS IN DETAIL

FOREWORD	xv
-----------------	-----------

ACKNOWLEDGMENTS	xvii
------------------------	-------------

INTRODUCTION	xix
---------------------	------------

Who This Book Is For	xx
What's in This Book?	xx
Requirements	xxii

PART I FOUNDATIONS

1 INTRODUCTION TO FUZZING	3
--------------------------------------	----------

Why Fuzz?	3
The Fuzzing Process	4
Generating Random Inputs	4
Exercising the Code Under Test	7
Evaluating Progress	7
Detecting Bad Behaviors	10
Fuzzing vs. Other Testing Types	12
Unit Testing	12
Integration Testing	12
Fuzz Testing	13
Wrapping Up	13

2 PREPARING ANDROID FOR FUZZING	15
--	-----------

Downloading Android	15
Setting Up Your Device	16
Physical Devices	17
Emulated Devices	18
The Soong Build System	19
Defining Build Targets	19
Building a Fuzz Target	21
Setting Build-Time Options	22

Installing ADB	22
Testing the Fuzzing Environment	23
With Cuttlefish	23
With a Physical Device	24
On Your Host Machine	25
With AFL++	25
Wrapping Up	26

3

TOOLS AND FRAMEWORKS

27

Sanitizers	27
Fuzzing Engines	29
libFuzzer	29
AFL++	29
LibAFL	30
Syzkaller	30
Data Parsing	31
Manual Parsing	32
With the FuzzedDataProvider Library	34
With the libprotobuf-mutator Library	35
Automating the Fuzzing Life Cycle	37
Analyzing Lines Covered	38
Wrapping Up	42

4

AN OVERVIEW OF ANDROID SECURITY

43

Layers of the Android Architecture	43
Android's Security Evolution	45
Hardware-Based Security	47
Trusted Execution Environments	48
Secure Elements	50
Protected Virtual Machines	51
Fragmentation	51
The Chinese Android Ecosystem	52
Project Treble	52
Permissions	53
How Apps Request Permissions	55
Permission Escalation Attacks	55
SELinux	56
How SELinux Works	56
Policy Structure	58
Tools	59
Shortcomings	59
App Signing	60
Wrapping Up	60

PART II FUZZING IN PRACTICE

5 CHOOSING YOUR TARGETS 65

Library Evaluation Metrics	65
The Number of Dependent Libraries	66
Reachability via Android Public APIs	67
The Days Since the First and Last Commit	68
The Number of Distinct Contributors	69
The Number of Lines Changed and Inserted	70
The Vulnerability History	70
Whether the Library Runs in Privileged Process	71
Calculating a Criticality Score	71
Determining a Library's Critical Components	73
Measuring Complexity with Lizard	74
Finding Dangerous Operations	74
Before You Begin Fuzzing	75
Wrapping Up	76

6 WRITING YOUR FIRST ANDROID FUZZ HARNESS 77

Fuzzing a Library	78
Creating an Empty Fuzz Harness	78
Running the Harness	80
Exercising the Library Code	80
Disabling Error Logging	84
Understanding the Fuzzer's Output	85
Fixing Memory Leaks	86
Improving Fuzzer Performance	88
Adding a Dictionary	88
Collecting a Corpus	89
Adding a Seed Corpus	91
Wrapping Up	91

7 CRASH ANALYSIS AND BUG TRIAGE 93

Initial Crash Validation	94
Do We Have Enough Information About the Bug?	94
Can We Reproduce the Issue?	96
Is It a Legitimate Bug?	98
Crash De-Duplication	99

Making a Severity Assessment	100
Behavior	101
Privilege Level	102
Attack Vector	103
The Final Determination	104
Wrapping Up	106

PART III ADVANCED TARGETS

8 SYSTEM SERVICES 109

A Blueprint for Fuzzing Large Systems	110
Challenges of Black-Box Fuzzing	110
API Contract Enforcement	111
Fuzzing Binder Services	113
Fuzzing Parcel Objects	113
Automating a Service Fuzzer	115
Fuzzing Multiple Services	117
Optimizing Coverage: A Binder-Specific Example	119
Considering Structure-Aware Fuzzing	120
The Human Element of Large-Scale Fuzzing	121
Developing a Strategy for Scaling	121
Testing the Fuzzer Framework	122
Wrapping Up	122

9 THE ANDROID KERNEL 123

Why Kernel Fuzzing Requires a Different Approach	123
Preparing a Kernel for Fuzzing	124
Downloading and Building Kernel Code	124
Turning on Fuzzing Instrumentation	126
Syzkaller	127
Setting Up	127
Getting to Know Syzkaller	128
Writing a Syzkaller Configuration	128
Fuzzing Inside a Sandboxed Environment	131
Linux Kernel Library	132
The Structure of an LKL-Based Fuzzer	133
Example: Fuzzing the Human Interface Device	133
The High-Level Workflow for Constructing an LKL Fuzzer	134
Syzkaller vs. LKL	135
Wrapping Up	135

10	FUZZING CUSTOM KERNEL DRIVERS	137
Introducing a New Driver		137
Adding a Driver to the Kernel		138
Implementing the Lockbox		140
Implementing the Padlock		144
Writing the Description		149
Describing the Lockbox		150
Describing the Padlock		151
Extracting Constants		153
Fuzzing Your New Description		156
Focusing on New Descriptions		157
Introducing a Bug		159
Running a Reproducer		163
Wrapping Up		166
 11	 HOST ENVIRONMENTS	 167
What Counts as a Host?		167
Why Fuzz Android on the Host?		168
Challenges		169
Enabling Host Fuzzing		170
Turning On the Flag		170
Enabling the Host for All Dependencies		171
Mocking Platform-Specific Components		172
Host Fuzzing Beyond Android		173
Wrapping Up		174
 EPILOGUE: FUZZING IN THE AGE OF AI		 175
Fuzzing AI Models		176
Automating the Fuzzing Process		178
Solving Fuzzing's Challenges		179
With Gray-Box and White-Box Fuzzing		179
With LLM-Generated Inputs		181
By Automating Structure-Aware Mutation		182
Auto-Triage		183
Crash De-Duplication		183
Root Cause Analysis		183
Remediation		184
Wrapping Up		184
 INDEX		 185